

INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

VitalCloud Health
ISO/IEC 27001:2022 | HIPAA Compliant

Document Title	Information Security Management System (ISMS)
Document Number	VC-ISMS-001
Version	1.0
Classification	Internal — Confidential
Author	Daniel Nwachukwu
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Issue Date	May 11, 2026
Next Review Date	May 11, 2027
Distribution List	All Departments, Executive Team, HR, IT, Legal, Compliance

Table of Contents

1. Clause 4: Context of the Organization
2. Clause 5: Leadership and Commitment
3. Clause 6: Planning
4. Clause 7: Support
5. Clause 8: Operation
6. Clause 9: Performance Evaluation
7. Clause 10: Improvement

Clause 4: Context of the Organization

Organization: VitalCloud Health

Document ID: VC-ISMS-CLAUSE4-001

Referenced Clause: ISO/IEC 27001:2022 — Clause 4

Version: 1.0

Date: May 11, 2026

4.1 Understanding the Organization and Its Context

Introduction

VitalCloud Health is a rapid-growth telehealth provider connecting rural patients with specialist doctors via a proprietary mobile application and web portal. The organization recently acquired Legacy Care Clinics, a chain of physical offices that still uses paper records and unencrypted on-site servers. VitalCloud is actively pursuing a multi-million dollar contract with a national insurance provider that requires ISO 27001 certification and HIPAA compliance within 12 months. This document outlines the internal and external issues relevant to VitalCloud Health that affect its ability to achieve the intended outcomes of its ISMS.

External Issues

- **Regulatory Landscape:** Strict healthcare regulations including HIPAA, HITECH Act, and state privacy laws. Increasing enforcement actions and penalties for PHI breaches.
- **Threat Landscape:** High prevalence of ransomware attacks targeting healthcare organizations. Sophisticated phishing campaigns aimed at medical staff. Insider threats from undertrained legacy clinic employees.
- **Market Expectations:** National insurance provider and institutional partners require verified ISO 27001 certification and HIPAA compliance before contract execution.
- **Technological Shifts:** Rapid adoption of IoT medical devices (wearable heart monitors), telemedicine video streaming, and cloud-based EHR systems. Legacy systems from acquired clinics create integration challenges.
- **Environmental Hazards:** Natural disasters affecting rural clinic locations. Power outages disrupting telemedicine services and EHR access.
- **Government Policies:** Evolving telehealth reimbursement policies. Federal mandates for interoperability and patient data portability.
- **External Stakeholders:** Patients, insurance providers, regulatory bodies (HHS/OCR), medical device vendors, cloud service providers, and independent practitioners.

Internal Issues

- **Organizational Culture:** Transitioning from a rapid-growth startup mindset to a structured, security-first and compliance-driven healthcare culture.
- **Resource Allocation:** Balancing budget between feature development for the telehealth platform and robust security infrastructure required for HIPAA and ISO 27001.
- **Remote Workforce:** Distributed medical staff, independent practitioners, and IT teams accessing PHI from varied home networks and personal devices.
- **Legacy Systems:** Acquired Legacy Care Clinics use paper records and unencrypted on-site servers, creating significant compliance gaps and data protection risks.
- **Lack of Data Protection:** Inconsistent encryption standards across acquired clinic systems. Unencrypted PHI at rest and in transit in legacy environments.
- **Network Unavailability:** Dependency on internet connectivity for telemedicine services. Single points of failure in rural clinic network infrastructure.
- **Untrained Employees:** Legacy Care Clinics staff lack training on HIPAA requirements, information security policies, and secure handling of PHI.
- **Inefficient/Outdated Technology:** Legacy imaging equipment, outdated operating systems, and unsupported software in acquired clinic locations.

4.2 Understanding the Needs and Expectations of Interested Parties

VitalCloud Health has identified the following stakeholders and their requirements:

Interested Party	Requirements / Expectations
Patients	Protection of PHI; 24/7 telemedicine availability; right to access, amend, and delete their health records (Right to be Forgotten); secure video consultations.
National Insurance Provider	Proof of ISO 27001 certification and HIPAA compliance; secure API integrations; timely breach notification; audit rights.
HHS / OCR (Regulators)	Compliance with HIPAA Privacy, Security, and Breach Notification Rules; timely reporting of breaches; acceptable safeguards for PHI.
Independent Practitioners	Secure remote access to patient records; clear security policies; reliable telemedicine platform; data minimization.
Medical Device Vendors	Secure API handshakes for IoT data transmission; compliance with FDA cybersecurity guidance for connected devices.
Employees & Contractors	Clear security policies; secure remote access tools; regular training on HIPAA and information security.
Shareholders / Investors	Protection of intellectual property (proprietary telehealth algorithms); brand reputation;

	regulatory compliance enabling growth.
--	--

4.3 Determining the Scope of the ISMS

The scope of the ISMS includes all information assets, technologies, processes, and personnel supporting VitalCloud Health's telehealth ecosystem and acquired physical clinics.

- **Technical Scope:** The VitalCloud Health mobile application (iOS/Android), the patient/doctor web portal, the cloud-based EHR system, telemedicine video streaming infrastructure, IoT medical device integration platform, and legacy clinic servers.
- **Physical Scope:** VitalCloud Health headquarters, all Legacy Care Clinics physical locations, secure data center/cloud hosting environment (AWS/Azure), and medical device storage areas.
- **Organizational Scope:** All full-time employees, contractors, independent practitioners, third-party developers, and vendors with access to PHI or production environments.
- **Exclusions:** Personal devices of patients (BYOD policy applies but device management is excluded); internal networks of third-party insurance providers (managed via BAA and Vendor Risk Management).

4.4 Information Security Management System (ISMS)

VitalCloud Health hereby establishes, implements, maintains, and continually improves an ISMS in accordance with the requirements of ISO/IEC 27001:2022 and HIPAA Security Rule.

The ISMS Lifecycle includes:

- **Planning:** Establishing risk assessment methodologies, HIPAA gap analysis, and security objectives aligned with healthcare regulatory requirements.
- **Support & Operation:** Implementing controls defined in the Statement of Applicability (SoA), including technical safeguards (encryption, access controls), physical safeguards (secure areas), and administrative safeguards (policies, training).
- **Performance Evaluation:** Conducting internal audits, vulnerability assessments, penetration testing, and management reviews with HIPAA compliance metrics.
- **Improvement:** Managing non-conformities, implementing corrective actions, and addressing gaps identified during HIPAA risk analyses and ISO 27001 audits.

Next Review Date: May 2027

Owner: ISMS Steering Committee

Clause 5: Leadership and Commitment

Document ID: VC-ISMS-CLAUSE5-001

Referenced Clause: ISO/IEC 27001:2022 — Clause 5

1. Purpose

This document outlines how VitalCloud Health demonstrates leadership and commitment to the development, implementation, and continual improvement of the Information Security Management System (ISMS), ensuring alignment with HIPAA requirements and the organization's strategic objectives in the telehealth sector.

2. Leadership Commitment

Executive leadership at VitalCloud Health is fully committed to the effectiveness of the ISMS and HIPAA compliance program and:

- Ensures the information security policy and objectives align with strategic business goals and healthcare regulatory requirements.
- Allocates necessary resources for the establishment, implementation, and maintenance of the ISMS and HIPAA safeguards.
- Promotes continual improvement and integration of the ISMS into all business processes, including telemedicine operations and clinic management.
- Supports roles and responsibilities for information security and HIPAA compliance across all levels of the organization.
- Ensures that the ISMS achieves its intended outcomes, including protection of PHI and maintenance of telemedicine service availability.

3. Information Security Policy

The executive team has approved a formal Information Security Policy that:

- Is appropriate to the purpose and context of VitalCloud Health as a telehealth provider handling Protected Health Information (PHI).
- Includes a commitment to satisfy applicable requirements, including HIPAA, HITECH Act, and ISO 27001:2022.
- Includes a commitment to continual improvement of the ISMS.
- Explicitly addresses the protection of patient privacy, data integrity, and service availability.

The policy is communicated within the organization and is available to relevant interested parties, including patients upon request.

4. Organizational Roles, Responsibilities, and Authorities

VitalCloud Health's management ensures that roles relevant to information security and HIPAA compliance are clearly defined and communicated.

Role	Responsibilities
Chief Executive Officer (CEO)	Ultimate accountability for ISMS and HIPAA compliance. Approves policies and resource allocation.
Chief Information Security Officer (CISO)	Leads the Information Security Program, oversees HIPAA Security Rule compliance, and ensures alignment with ISO 27001.
HIPAA Privacy Officer	Ensures compliance with HIPAA Privacy Rule, manages patient rights requests, and oversees PHI use and disclosure policies.
HIPAA Security Officer	Implements and maintains HIPAA technical, physical, and administrative safeguards. Conducts risk analyses.
ISMS Manager	Oversees day-to-day operations of the ISMS, risk management activities, and internal audit program.
Department Heads	Ensure departmental compliance with ISMS policies, HIPAA procedures, and support awareness training.
IT Security Officer	Monitors threats, incidents, and compliance with technical controls. Manages SIEM, IDS/IPS, and endpoint protection.
All Employees	Adhere to security policies, HIPAA procedures, and report any suspicious activities or potential breaches immediately.

5. Communication and Direction

Top management regularly communicates the importance of effective information security management and HIPAA compliance through:

- Monthly all-hands briefings with security and compliance updates
- Quarterly HIPAA training and security awareness programs
- Internal newsletters highlighting security best practices and breach case studies
- Quarterly management review meetings with ISO 27001 and HIPAA KPIs
- Annual HIPAA risk analysis reviews

6. Review and Continual Improvement

Leadership participates in regular management reviews to:

- Assess ISMS performance and HIPAA compliance status
- Review security objectives and risks, including those related to PHI
- Monitor progress on corrective actions and remediation plans
- Identify opportunities for improvement in telemedicine security and clinic operations

This document demonstrates VitalCloud Health's alignment with Clause 5 of ISO/IEC 27001:2022 and affirms management's commitment to protecting information assets and patient privacy.

Next Review Date: May 2027

Owner: Executive Management / CISO

Clause 6 & 7: Planning and Support

Document ID: VC-ISMS-CLAUSE67-001

Referenced Clauses: ISO/IEC 27001:2022 — Clause 6 & Clause 7

Clause 6: Planning

6.1 Actions to Address Risks and Opportunities

VitalCloud Health identifies risks and opportunities that could affect the ISMS's ability to achieve its intended outcomes, particularly those related to PHI protection, telemedicine service continuity, and HIPAA compliance. These actions:

- Ensure the ISMS can achieve its goals, including HIPAA Security Rule compliance and ISO 27001 certification.
- Prevent or reduce undesired effects, such as PHI breaches, service outages, and regulatory penalties.
- Achieve continual improvement of security posture across telehealth and clinic operations.

Planned Actions:

- Comprehensive risk identification and evaluation covering telehealth platforms, IoT devices, legacy clinic systems, and PHI handling.
- Control implementation (technical, physical, administrative) aligned with ISO 27001 Annex A and HIPAA safeguards.
- Business impact analysis for telemedicine services and disaster recovery planning for clinic operations.
- HIPAA gap analysis and remediation plan to address deficiencies in Legacy Care Clinics.

6.2 Information Security Risk Assessment

The organization has implemented a Risk Assessment Methodology that:

- Establishes and maintains criteria for risk acceptance, including HIPAA-specific risk thresholds.
- Identifies information security risks related to the loss of confidentiality, integrity, and availability of PHI and telehealth systems.
- Analyzes the likelihood and impact of risks using a 5×5 risk matrix.
- Determines risk levels and prioritizes based on business impact, patient safety, and regulatory consequences.
- Documents results in a Risk Register, including HIPAA-specific risks.

Frequency: Annually or upon major system/process changes, acquisition of new clinics, or

significant threat landscape changes.

Tools Used: 5x5 Risk Assessment Matrix, Asset Register, Threat Catalogue, HIPAA Risk Analysis Worksheet.

6.3 Information Security Risk Treatment

Risk treatment options include:

- Risk mitigation by applying controls from Annex A and HIPAA Security Rule safeguards.
- Risk avoidance by discontinuing high-risk activities (e.g., decommissioning unencrypted legacy servers).
- Risk transfer via cyber insurance and Business Associate Agreements (BAAs) with vendors.
- Risk acceptance when residual risk is within the risk appetite and documented with management approval.

A Risk Treatment Plan (RTP) is documented and approved by management, with specific timelines for HIPAA remediation.

6.4 Information Security Objectives and Planning to Achieve Them

VitalCloud Health sets SMART information security objectives aligned with healthcare requirements:

Objective	Target	Responsibility	Deadline
Achieve ISO 27001:2022 certification	Successful external audit with zero major non-conformities	CISO / ISMS Manager	Q1 2027
Achieve HIPAA compliance across all operations	Zero critical gaps in HIPAA Security Rule assessment	HIPAA Security Officer	Q4 2026
Reduce phishing-related incidents	50% reduction in successful phishing attempts	IT Security Officer	Q3 2026
Complete security and HIPAA awareness training	100% staff trained (including legacy clinic employees)	HR / HIPAA Privacy Officer	Q2 2026
Improve incident response time for PHI breaches	≤ 30 minutes average detection; ≤ 1 hour containment	IR Team Lead	Q4 2026
Encrypt all PHI at rest and in transit	100% encryption coverage across all systems	IT Security Officer	Q3 2026
Migrate legacy clinic systems to secure cloud HER	100% of Legacy Care Clinics on encrypted cloud EHR	CIO / IT Director	Q2 2027

Objectives are monitored through KPIs and reviewed quarterly by the ISMS Steering Committee and HIPAA Compliance Committee.

Clause 7: Support

7.1 Resources

Top management ensures that sufficient resources are provided to:

- Implement and maintain the ISMS and HIPAA compliance program.
- Conduct risk assessments, HIPAA risk analyses, and internal audits.
- Support incident response, breach notification, and business continuity for telemedicine services.
- Provide technical infrastructure (encryption, SIEM, IDS/IPS) and administrative support (policies, training).
- Fund the migration of Legacy Care Clinics to secure, HIPAA-compliant systems.

7.2 Competence

Personnel are evaluated to ensure they are competent based on education, training, skills, and experience. Annual training plans and skill assessments are conducted for all security-critical and HIPAA-covered roles, including:

- HIPAA Privacy and Security Rule training for all staff handling PHI
- ISO 27001 internal auditor certification for audit team members
- Specialized training for IT staff on healthcare cybersecurity (HITRUST, NIST CSF)
- Clinical staff training on secure telemedicine practices and patient privacy

7.3 Awareness

All employees are made aware of:

- The information security policy and HIPAA policies.
- Their role in protecting PHI and maintaining ISMS effectiveness.
- The consequences of non-compliance, including HIPAA violations and disciplinary actions.

Awareness is reinforced via:

- Monthly cyber hygiene and HIPAA privacy campaigns
- Quarterly phishing simulations targeting telehealth and clinic staff
- Annual training refreshers with HIPAA case studies
- Posters and digital signage in clinic locations

7.4 Communication

VitalCloud Health has established a communication framework to determine what, when, and with whom to communicate, including HIPAA breach notification requirements.

Topic	Audience	Frequency	Method
ISMS updates	All staff	Quarterly	Email, Intranet, Staff Meetings
HIPAA policy updates	All PHI-handling staff	As needed / Annually	Email, Training Portal, Binders
Risk updates	Risk Committee / CISO	Monthly	Meetings, Dashboard
Incident reports (including breaches)	Executive team / HIPAA Officers	As needed / Within 24hrs for breaches	Secure email, Dashboard, Phone
Breach notification (patients)	Affected patients / HHS	Within 60 days (HIPAA)	Mail, Email, HHS Portal

Breach notification (media)	Public / Media	Within 60 days if >500 affected	Press release, Website
-----------------------------	----------------	---------------------------------	------------------------

7.5 Documented Information

VitalCloud Health ensures:

- Documentation is approved prior to issue by the CISO or designated authority.
- Documents are reviewed, updated, and re-approved as needed (at least annually).
- Records are controlled and protected against loss, unauthorized access, and tampering.

Document Types Maintained:

- Policies and procedures (Information Security Policy, HIPAA Policies, BAA templates)
- Risk assessments and HIPAA risk analyses
- Audit reports and corrective action logs
- Incident logs and breach investigation reports
- Training records and competency assessments
- Business Associate Agreements and vendor risk assessments

Next Review Date: May 2027

Owner: ISMS Manager / HIPAA Security Officer

Clause 8: Operation

Document ID: VC-ISMS-CLAUSE8-001

Referenced Clause: ISO/IEC 27001:2022 — Clause 8

8.1 Operational Planning and Control

VitalCloud Health plans, implements, and controls its operational processes as needed to meet the requirements of the ISMS, manage information security risks, and ensure HIPAA compliance. This includes:

- Implementing the risk treatment plan, including HIPAA remediation actions for Legacy Care Clinics.
- Establishing policies, procedures, and technical controls for telemedicine operations, EHR management, and IoT device security.
- Verifying the effectiveness of controls through continuous monitoring, vulnerability scanning, and penetration testing.
- Documenting evidence of operational activities (e.g., access logs, backup records, incident reports, audit trails).

Operational Controls Include:

- Access management (logical and physical) — Role-based access control (RBAC) for PHI, MFA for all systems, privileged access monitoring.
- Endpoint protection and patching — Anti-malware on all endpoints, automated patching for telehealth app servers and clinic workstations.
- Network segmentation and firewall policies — Separation of telemedicine video streams from EHR databases; VLANs for IoT devices.
- Backup and recovery — Daily encrypted backups of EHR data, quarterly restoration testing, offsite/cloud backup for disaster recovery.
- Third-party risk management — BAAs with all vendors handling PHI, annual security assessments of cloud providers and medical device vendors.
- IoT device security — Encryption of data from wearable heart monitors, secure API authentication, firmware update management.
- Physical security — Access controls, CCTV, and visitor logs at all Legacy Care Clinic locations and HQ.

All operations are consistent with the Risk Assessment and Treatment process, and results are retained as documented information.

8.2 Information Security Risk Assessment

Risk assessments are performed:

- At planned intervals (annually)
- When significant changes occur (e.g., acquisition of new clinics, deployment of new telehealth features, changes in threat landscape)
- Following any security incident or breach involving PHI

Each risk is logged in the Risk Register and assigned an owner responsible for tracking mitigation status. Results are validated and approved by the ISMS Manager, HIPAA Security Officer, and Risk Committee.

8.3 Information Security Risk Treatment

Based on the assessment:

- Appropriate controls are selected from Annex A, HIPAA Security Rule, and NIST CSF.
- Treatment plans are executed by control owners with defined timelines.
- Residual risks are reviewed and, if acceptable, formally approved by top management.

All treatment activities are monitored, and status updates are included in ISMS performance reports and HIPAA compliance dashboards.

Key Risk Treatment Artifacts:

- Risk Treatment Plan (RTP)
- Statement of Applicability (SoA)
- Control Implementation Records
- HIPAA Remediation Plan
- Business Associate Agreements (BAAs)

8.4 Response to Information Security Incidents

VitalCloud Health maintains a structured Incident Response Plan aligned with HIPAA Breach Notification Rules to address and manage security incidents efficiently.

The process includes:

Identification — Logging incidents through the Security Operations Center (SOC), helpdesk, or automated monitoring systems (SIEM).

Assessment — Categorizing the type and severity of the incident; determining if PHI is involved and if breach notification is required.

Containment — Isolating affected systems, revoking compromised credentials, and initiating short-term controls to prevent further exposure.

Eradication — Removing the root cause (e.g., malware, unauthorized access), patching vulnerabilities, and verifying system integrity.

Recovery — Restoring operations and data from verified clean backups; resuming telemedicine services and EHR access.

Lessons Learned — Conducting post-incident reviews; updating policies, controls, and training based on findings.

Types of Incidents Covered:

- Malware and ransomware infections targeting telehealth infrastructure
- Unauthorized access attempts to EHR systems or patient portals
- Insider threats (intentional or accidental) from employees or contractors
- Phishing attacks targeting medical staff and independent practitioners
- PHI data breaches requiring HIPAA notification
- IoT device compromise or data interception
- Telemedicine session hijacking or video stream interception

All incidents are recorded in the Incident Register, and incident response metrics (e.g., time to detect, respond, and resolve) are monitored. Breach determination and notification follow HIPAA timelines (notification to HHS within 60 days; notification to affected individuals within 60 days; media notification if >500 individuals affected).

8.5 Management of Changes

All changes impacting ISMS are controlled through a formal Change Management Process:

- Risk assessments are updated for proposed changes.
- Changes to policies, processes, or technology are documented and approved.
- Security implications and HIPAA compliance impacts are evaluated prior to implementation.

Examples include:

- Onboarding of third-party service providers (requires BAA and security assessment)
- Changes in infrastructure (cloud migration, EHR system upgrades, IoT device integration)
- Policy and procedure revisions (including HIPAA policies)
- Acquisition of new clinic locations (requires security assessment and remediation plan)

Next Review Date: May 2027

Owner: ISMS Manager / HIPAA Security Officer

Clause 9: Performance Evaluation

Document ID: VC-ISMS-CLAUSE9-001

Referenced Clause: ISO/IEC 27001:2022 — Clause 9

9.1 Monitoring, Measurement, Analysis and Evaluation

VitalCloud Health monitors and measures the performance and effectiveness of the ISMS and HIPAA compliance program using defined KPIs and metrics. This includes:

- Control effectiveness (e.g., encryption coverage, access review completion, patch management status)
- Training completion rates (HIPAA and information security awareness)
- Risk treatment implementation status and residual risk levels
- Incident detection and response times (MTTD, MTTR)
- PHI breach metrics and notification compliance
- Telemedicine platform uptime and availability

Performance Metrics Monitored:

Metric	Target	Frequency	Owner
% of completed risk assessments	100%	Annually	ISMS Manager
Mean Time to Detect (MTTD)	≤ 30 minutes	Monthly	IT Security Officer
Mean Time to Respond (MTTR)	≤ 1 hour	Monthly	IR Team Lead
% of controls tested and effective	≥ 95%	Quarterly	CISO
PHI encryption coverage	100%	Monthly	IT Security Officer
Staff training completion rate	100%	Quarterly	HR / HIPAA Privacy Officer
Telemedicine platform uptime	≥ 99.9%	Monthly	IT Director
Breach notification compliance	100% within HIPAA timelines	Per incident	HIPAA Privacy Officer

Results are recorded and reviewed quarterly by the ISMS Steering Committee and HIPAA Compliance Committee.

9.2 Internal Audit

VitalCloud Health has established an internal audit program to:

- Determine whether the ISMS conforms to ISO 27001:2022 requirements and internal criteria.

- Assess whether the ISMS is effectively implemented and maintained.
- Verify HIPAA Security Rule compliance and identify gaps.

Audit Frequency: At least annually or based on risk (e.g., after acquisition of new clinics or major system changes).

Auditor Independence: Auditors are independent of the activities they audit. HIPAA audits are conducted by personnel with healthcare compliance expertise.

Internal Audit Process:

Audit Planning: Based on risk, scope, and schedule. Includes ISO 27001 clauses, Annex A controls, and HIPAA safeguards.

Execution: Evidence gathering through interviews, observations, document review, and technical testing (vulnerability scans, access reviews).

Reporting: Audit findings and non-conformities documented and reported to management and the HIPAA Compliance Committee.

Follow-up: Verification of corrective actions and remediation of HIPAA gaps.

Audit Artifacts Maintained:

- Internal Audit Plan
- Audit Checklist (ISO 27001 + HIPAA)
- Audit Reports
- Corrective Action Logs
- HIPAA Gap Analysis Reports

9.3 Management Review

Top Management conducts periodic reviews to ensure the ISMS remains suitable, adequate, and effective for VitalCloud Health's telehealth and clinic operations.

Review Frequency:

Annually, or as needed based on significant events (e.g., PHI breach, acquisition, major audit findings, regulatory changes).

Inputs to Management Review:

- Status of actions from previous reviews
- Changes in external and internal issues (regulatory, threat landscape, business growth)
- ISMS performance (including audit results, incidents, and objectives)
- HIPAA compliance status and risk analysis results
- Feedback from interested parties (patients, insurance provider, regulators)
- Opportunities for continual improvement
- Results of vendor risk assessments and BAA compliance

Outputs from Management Review:

- Decisions on improvements to ISMS and HIPAA program
- Resource needs (budget, personnel, technology)
- Changes to policies, objectives, or risk appetite
- Prioritization of remediation actions for Legacy Care Clinics

All review activities and decisions are documented in Management Review Meeting Minutes and maintained as part of ISMS records.

Next Review Date: May 2027

Owner: ISMS Manager / CISO

Clause 10: Improvement

Document ID: VC-ISMS-CLAUSE10-001

Referenced Clause: ISO/IEC 27001:2022 — Clause 10

10.1 Nonconformity and Corrective Action

VitalCloud Health ensures that any nonconformities related to the ISMS and HIPAA compliance are addressed through a defined corrective action process.

When a nonconformity occurs:

Identification and Logging: Nonconformities are recorded in the Nonconformity and Corrective Action Register, including HIPAA violations and audit findings.

Immediate Action: Short-term actions are taken to mitigate any immediate risks or impacts, including containment of PHI exposure.

Root Cause Analysis: Performed to identify the underlying causes of the nonconformity (e.g., lack of training, inadequate controls, process gaps).

Corrective Action: Determined and implemented to prevent recurrence, with defined timelines and responsible parties.

Verification: Effectiveness of corrective actions is assessed through follow-up audits, testing, and monitoring.

Documentation: All steps are documented and retained as evidence for ISO 27001 audits and HIPAA investigations.

Sources of Nonconformity Include:

- Internal audit findings (ISO 27001 and HIPAA)
- External audit reports (certification body, OCR investigations)
- Incident reports and breach investigations
- Risk assessment results and gap analyses
- Staff or stakeholder feedback
- Patient complaints related to privacy or security
- Vendor security assessment findings

Corrective actions are reviewed by the ISMS Manager and HIPAA Security Officer and tracked until resolution. Significant nonconformities are escalated to the CISO and Executive Management.

10.2 Continual Improvement

VitalCloud Health is committed to continually improving the effectiveness, suitability, and adequacy of the ISMS and HIPAA compliance program. This includes:

- Regular reviews of policies, procedures, and controls to address evolving threats and regulatory requirements.
- Use of performance evaluation results to identify areas for enhancement.
- Incorporation of industry best practices (NIST CSF, HITRUST, CIS Controls) and updated regulatory requirements (HIPAA, state laws).
- Engagement with stakeholders (patients, practitioners, insurance provider) to collect feedback on security and privacy.
- Post-incident and post-breach reviews to integrate lessons learned into the ISMS.
- Technology upgrades and control optimization based on risk assessment outcomes.

Improvement Mechanisms:

- Management reviews with ISO 27001 and HIPAA KPIs
- Staff awareness and HIPAA training programs
- Technology upgrades (EHR migration, encryption enhancement, SIEM deployment)
- Control optimization (RBAC refinement, MFA expansion, network segmentation)
- Lessons learned from incidents, audits, and breach investigations
- Benchmarking against healthcare industry standards (HITRUST, NIST CSF)

Improvement actions are monitored for effectiveness, documented, and presented to Top Management as part of ISMS review meetings. The ISMS Improvement Plan is updated quarterly and aligned with the organization's strategic objectives and HIPAA compliance roadmap.

Next Review Date: May 2027

Owner: ISMS Manager / CISO

Document Approval

This ISMS Document has been reviewed and approved by the following authorized personnel:

Name	Title	Signature	Date
	Chief Executive Officer (CEO)	_____	_____
	Chief Information Security Officer (CISO)	_____	_____
	HIPAA Security Officer	_____	_____
Daniel Nwachukwu	ISMS Manager	_____	_____

This document is the property of VitalCloud Health. Unauthorized disclosure, copying, or distribution is prohibited. All staff must acknowledge receipt and understanding of this document.